PHPに何が起きたのか

PHP2Shell：ウェブサイトの裏側を支えるPHP本体の問題

ログイン前でも攻撃される恐れ

2026年10月21日、PHP開発チームは2件の重大な脆弱性の修正版を公開した。条件がそろうと、認証していない攻撃者がサーバー上で不正なコードを実行できる。

PHPとは？

WordPressなどで使われる、サーバー側のプログラミング言語。ページの生成や入力内容の処理を担う。

CVE-2026-109618

メモリ不足時の処理で内部データが不完全な状態になり、不正なメモリ処理からコード実行につながる恐れ。

CVE-2026-109619

解放済みのメモリに関わる古い内部状態が残り、後続のリクエストで利用されることからコード実行につながる恐れ。

深刻度は、いずれも9.2 / 10

CVSS v4.0で「Critical」に相当。実際の攻撃の成否は構成や設定にも左右される。

管理画面のパスワード強化だけでは、根本的に防げない。

どんな危険があるのか

被害の範囲は、PHPが持つ権限やアクセスできる情報で変わる

01 情報の流出

サーバー内の設定情報や認証情報、接続可能なデータベースの情報などを盗まれる恐れ。

02 サイトの改ざん

ページやリンクの書き換え、偽の入力画面の設置などを通じて、利用者にも被害が広がる恐れ。

03 サービスの停止・侵入の長期化

処理の妨害や不正ファイルの設置により、営業停止や再侵入につながる可能性。

対象はWordPressだけではない

PHP公式は、ウェブからのリクエストを処理するPHP環境を広く注意の対象としている。PHP-FPM、Apacheのmod_php、php-cgi、FrankenPHP、LiteSpeedなどが含まれる。

特にmod_phpでは、アプリケーションのコードが動く前に攻撃が成立する実証例がある。ログイン画面を設けただけで安心はできない。

ここに示すのは想定被害。全サイトが侵害済みという意味ではない。

根本対策は、PHP本体の更新

WordPress本体やプラグインの更新とは、別に確認する

今回の修正が入ったバージョン

PHP 8.2	8.2.35
PHP 8.3	8.3.36
PHP 8.4	8.4.27
PHP 8.5	8.5.12

同じ系列の上記修正版以降、または配布元が今回の修正を適用したパッケージを使う。表示バージョンだけで判断せず、提供元の告知も確認。

確認 → 保全 → 更新 → 点検

① サーバー管理画面や契約先で、PHPの利用有無と修正状況を確認。

② ファイル・データベースをバックアップし、互換性を確認。

③ PHPを更新し、必要なプロセスの再起動・更新漏れの点検を行う。

④ 表示やログイン動作、不審なファイルや通信を確認する。

PHP 8.1以前はPHP本体の通常サポートが終了している。修正の提供状況を配布元へ確認し、サポート中の系列への移行を進めたい。

レンタルサーバーは「今回の2件のCVEに対応済みか」を確認。

更新できないとき、どうするか

応急策・侵害後の対応・一般の利用者ができること

応急策だけで「安全」と判断しない

公式には一部の攻撃経路を減らす設定変更があるが、完全な解決は更新のみ。管理者と相談し、アクセス制限や対象サービスの一時停止も検討する。

設定値を、そのままねしない

アップロード進捗機能の無効化などは、特定の経路に対する緩和策。メモリ制限の変更には可用性への影響もあり、環境全体を見て判断する。

侵入の疑いがあるなら、更新だけで終わらせない

修正版にしても、既に置かれた不正ファイルまで消えるわけではない。ログなどを保全し、侵害範囲を調査。必要に応じて安全な環境から復旧し、認証情報を変更する。

一般の利用者は、公式の案内を確認

相手のサーバーを修正するのは運営者。サービスの注意喚起を確認し、不自然なログイン・決済画面では入力を止める。案内された手続きは、公式アプリや既知の公式サイトから行う。

「普通に表示されている」だけでは、安全性は判断できない。